

SAST - ANALYSE STATIQUE DE SÉCURITÉ

=====

DÉFINITION

SAST (Static Application Security Testing) analyse le code source pour détecter des vulnérabilités sans exécuter l'application.

OUTILS POPULAIRES

1. BANDIT (Python)

Installation: `pip install bandit`

Commande: `bandit -r src/ -f json`

Règles détectées: SQL injection, command injection, hardcoded passwords

2. SONARQUBE/SONARCLOUD

- Analyse multi-langages
- Intégration CI/CD native
- Dashboard de qualité
- Règles sécurité: 500+ pour Python

3. CHECKMARX

- Solution entreprise
- Analyse profonde
- Rapports détaillés

INTÉGRATION GITHUB ACTIONS

name: SAST Pipeline

on: [push, pull_request]

jobs:

bandit-scan:

runs-on: ubuntu-latest

steps:

- uses: actions/checkout@v4

- name: Run Bandit

run: |

pip install bandit

bandit -r src/ -f json -o bandit-report.json

- name: Upload results

uses: actions/upload-artifact@v3

with:

name: sast-reports

path: bandit-report.json

BONNES PRATIQUES

- Exécuter sur chaque PR
- Configurer quality gates
- Ignorer les faux positifs documentés
- Intégrer dans l'IDE des développeurs